

Security+ 5.1 · Security Policies

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.1** — Security Policies (11:02) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Security policies define what must be protected and are high-level documents. Standards specify how to implement policies technically. Procedures provide step-by-step instructions. An Acceptable Use Policy (AUP) defines what users can do with corporate resources. Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP) ensure business continuity during disruptions.

High-Yield Core Concepts Tested on Exam

- Policy: high-level, defines what to protect
- Standard: more technical, defines how to implement policy
- Procedure: step-by-step instructions for a task
- AUP: defines acceptable use of corporate resources
- BCP/DRP: plans for business continuity and disaster recovery

Exam Tips & Classic Scenarios

- If the question mentions a high-level document stating what to protect, choose policy.
- AUP is about user behavior; BCP/DRP are about business continuity.

Typical Exam Scenario: A document states that all customer data must be protected with encryption. This is a policy.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.1 — Security Policies)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

2. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

3. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'AUP: what the user CAN do with corporate resources'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: AUP: what the user CAN do with corporate resources...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'high-level document stating what to protect' = policy. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'high-level document stating what to protect' = policy
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'document that defines that data needs protection' = policy. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'document that defines that data needs protection' = policy...

6. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'AUP: what the user CAN do with corporate resources'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: AUP: what the user CAN do with corporate resources

8. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'high-level document stating what to protect'=policy. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'high-level document stating what to protect'=policy...

9. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'document that defines that data needs protection' = policy.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'document that defines that data needs protection' = policy....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Security Policies): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.1), an analyst evaluates the following technical requirement: 'Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Implement the corresponding solution: Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.
- *Prevent, Punish, Predict, Prove, Publish:* These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

2) A — Implement the corresponding solution: Policy: the 'what'. Standard: the 'how'.

Procedure: the step-by-step..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step. Policies state high-level intent and mandatory requirements; standards define specific technical or operational rules; procedures provide detailed, sequential instructions for execution.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) A — Implement the corresponding solution: AUP: what the user CAN do with corporate resources....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): AUP defines what the user CAN do with corporate resources. An Acceptable Use Policy (AUP) is a critical administrative control that outlines permitted and prohibited activities, helping enforce security and compliance.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) C — Implement the corresponding solution: 'high-level document stating what to protect' = policy.

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): 'high-level document stating what to protect' = policy. A security policy is a high-level document that outlines an organization's security objectives, defines what needs to be protected, and provides a framework for implementing controls.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'document that defines that data needs protection' = policy....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): 'document that defines that data needs protection' = policy.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Policy: the 'what'. Standard: the 'how'.

Procedure: the step-by-step....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) D — Implement the corresponding solution: AUP: what the user CAN do with corporate resources.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): AUP: what the user CAN do with corporate resources. An Acceptable Use Policy defines permitted and prohibited activities on corporate assets.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: 'high-level document stating what to protect'=policy....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): 'high-level document stating what to protect'=policy.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'document that defines that data needs protection' = policy.....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): 'document that defines that data needs protection' = policy. A security policy is a formal document that outlines an organization's security requirements, including data protection. It establishes rules and responsibilities for safeguarding information assets.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.1 (Security Policies): Policy: the 'what'. Standard: the 'how'. Procedure: the step-by-step.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.